

Bagaimana Ransomware as a Service Berkerja? Studi Deskriptif Eksplanatif Model Bisnis dan Tata Kelola Ekosistem Ransomware as a Service

Bilal¹

¹ Program Studi Teknik Informatika, STMIK Tazkia, Bogor, Indonesia

E-mail : bilalfarhani635@gmail.com

Abstrak

Ransomware-as-a-Service (RaaS) telah mengubah ransomware dari kejahatan siber sporadis menjadi industri semi-formal yang terstruktur. Penelitian deskriptif-eksplanatif ini menyintesis sepuluh kajian akademik/preprint dan dua laporan *threat-intelligence* kontemporer untuk menjawab tiga pertanyaan: (1) bagaimana RaaS berbeda dari ransomware konvensional dalam pembagian peran dan *revenue*; (2) bagaimana komponen ekosistem RaaS berinteraksi; (3) bagaimana mekanisme *vetting* afiliasi mencerminkan selektivitas di luar motif finansial. Melalui studi pustaka dan analisis dokumen sekunder tanpa akses *dark web* langsung, penelitian ini menemukan bahwa RaaS memisahkan peran *developer* dan afiliasi dengan skema bagi hasil rata-rata 85:15 yang tumbuh eksponensial seiring reputasi, berbeda signifikan dari ransomware konvensional yang stagnan setelah tahun pertama. Ekosistem ini melibatkan *Initial Access Broker* (IAB) sebagai aktor ekonomi mandiri, bukan sekadar sub-kategori afiliasi. Mekanisme *vetting* terbukti berfungsi sebagai instrumen *quasi-corporate governance* berbasis kompetensi dan kepercayaan, bukan semata penyaring pembayar lisensi, meskipun sifatnya rapuh secara etis. Struktur yang matang dan resisten regulasi ini pada gilirannya menarik aktor negara untuk berkooptasi, mengadopsi kapabilitas, atau beroperasi sebagai afiliasi/IAB demi *plausible deniability*. Penelitian ini memberikan definisi operasional dan tipologi aktor sebagai baseline konseptual bagi kajian lanjutan tentang tata kelola dan kebijakan RaaS.

Kata kunci : Ransomware-as-a-Service; ekosistem kejahatan siber; tata kelola kriminal; *vetting* afiliasi; aktor negara

How Does Ransomware as a Service Work? A Descriptive Explanatory Study of the Business Model and Governance of the Ransomware as a Service Ecosystem

Abstract

Ransomware-as-a-Service (RaaS) has transformed ransomware from a sporadic crime into a semi-formal, structured industry. This descriptive-explanatory study synthesizes ten academic/preprint works and two contemporary *threat-intelligence* reports to answer three questions: (1) how RaaS differs from conventional ransomware in role division and revenue; (2) how RaaS ecosystem components interact; (3) how affiliate *vetting* reflects selectivity beyond financial motive. Using literature review and secondary document analysis without direct dark-web access, the study finds that RaaS separates developer and affiliate roles under an average 85:15 revenue-sharing scheme that grows exponentially with reputation, unlike conventional ransomware which stagnates after its first year. The ecosystem involves the *Initial Access Broker* (IAB) as an independent economic actor rather than a mere affiliate sub-category. *Vetting* mechanisms function as quasi-corporate governance instruments grounded in competence and trust rather than pure licensing filters, though they remain ethically fragile. This mature, regulation-resistant structure in turn attracts state-connected actors to co-opt, adopt, or operate within it as affiliates/IABs for plausible deniability. The study offers an operational definition and actor typology as a conceptual baseline for further governance and policy research on RaaS.

Keywords : Ransomware-as-a-Service; cybercrime ecosystem; criminal governance; affiliate *vetting*; state-sponsored actors

1. Pendahuluan

1.1 Latar Belakang

Kejahatan siber berbasis ekstorsi data telah menjadi salah satu ancaman infrastruktur digital paling merugikan secara global dalam satu dekade terakhir. Rata-rata pembayaran tebusan ransomware meningkat drastis dari sekitar \$22.500 per hari sebelum tahun 2020 menjadi \$332.500 per hari sesudahnya, atau sekitar 15 kali lipat [1]. Peningkatan ini tidak dapat dilepaskan dari perubahan mendasar pada cara ransomware diproduksi dan didistribusikan sebagai kejahatan.

Perubahan tersebut ditandai oleh pergeseran dari model serangan tunggal menuju model *Ransomware-as-a-Service* (RaaS), yaitu skema di mana pengembang *malware* menyewakan "kit" ransomware kepada pihak ketiga (afiliasi) dengan skema bagi hasil. Volume serangan ransomware tercatat meningkat 73% dalam satu tahun pada kuartal pertama 2024, dengan *LockBit*—salah satu operasi RaaS terbesar—mendominasi 23% dari seluruh serangan pada periode yang sama, sementara total biaya kejahatan siber global diproyeksikan mencapai \$10,5 triliun pada 2025 [2]. Data ini menunjukkan bahwa RaaS bukan sekadar varian teknis, melainkan model bisnis dominan yang membentuk lanskap ancaman siber kontemporer.

Sejumlah kajian terdahulu telah menyoroti berbagai aspek RaaS secara terpisah. Dari sisi ekonomi, model permainan (*game-theoretic*) klasik menunjukkan bahwa keputusan korban membayar tebusan bergantung pada perbandingan biaya pemulihan versus jumlah tebusan, namun model ini masih mengasumsikan satu penyerang tunggal dan belum mengakomodasi struktur multi-aktor RaaS [3]. Dari sisi teknis-organisasional, RaaS modern seperti *LockBit*, *BlackCat*, *Hive*, dan *DarkSide* terbukti menawarkan proposisi nilai berbeda—mulai dari kecepatan enkripsi, dukungan lintas platform, hingga tim dukungan pelanggan dan tim hubungan masyarakat internal [4]. Dari sisi evolusi historis, silsilah *Babuk-GandCrab-Sodinokibi* memperlihatkan bagaimana modularitas kode dan spesialisasi peran (pengembang, perekrut, negosiator) menjadi strategi bertahan hidup operasi RaaS di tengah tekanan penegakan hukum [5]. Analisis forensik atas dompet *blockchain* afiliasi RaaS juga mengonfirmasi pemisahan peran finansial yang konsisten antara pengembang dan afiliasi, dengan pola bagi hasil yang bervariasi antar keluarga RaaS [1]. Sementara itu, analisis atas kebocoran data internal Conti memberikan bukti langka mengenai struktur organisasi RaaS layaknya perusahaan—termasuk daftar gaji, tim riset dan pengembangan, serta tim intelijen sumber terbuka [6].

Meskipun demikian, terdapat celah penelitian (*research gap*) yang belum diisi secara eksplisit. Pertama, kajian yang ada cenderung berfokus pada satu lapisan analisis saja—ekonomi, teknis, atau organisasional—tanpa menyintesis ketiganya ke dalam satu kerangka yang koheren. Kedua, *Initial Access Broker* (IAB) sering disebut sepintas sebagai bagian dari rantai serangan, namun jarang dianalisis sebagai aktor ekonomi mandiri dengan logikanya sendiri [7]. Ketiga, dan yang terpenting, mekanisme *vetting* (penyaringan) afiliasi RaaS umumnya disinggung sebagai detail operasional semata, padahal ia berpotensi mencerminkan bentuk tata kelola informal yang lebih kompleks daripada sekadar penyaringan pembayar lisensi [8]. Keempat, keterkaitan antara ekosistem RaaS dan aktor negara masih berupa observasi yang tersebar dan belum diintegrasikan ke dalam pemahaman struktural tentang mengapa negara tertarik memanfaatkan ekosistem ini [9]; bahkan penelitian yang secara eksplisit mengangkat evolusi RaaS mengakui bahwa aspek tata kelola dan geopolitik berada di luar cakupannya [5].

Untuk mengisi celah tersebut, penelitian ini mengusulkan pendekatan deskriptif-eksplanatif yang menyintesis literatur akademik, laporan *threat-intelligence*, dan laporan insiden publik ke dalam satu kerangka analisis terpadu. Alih-alih menguji hipotesis atau variabel kuantitatif, penelitian ini membangun definisi operasional, tipologi aktor, dan peta konseptual ekosistem RaaS—dengan penekanan khusus pada mekanisme *vetting* afiliasi sebagai unit analisis utama yang menjembatani perspektif ekonomi, organisasional, dan tata kelola.

Dengan demikian, penelitian yang berjudul "Bagaimana RaaS Bekerja? Studi Model Bisnis dan Ekosistem Ransomware-as-a-Service" ini menjadi penting sebagai baseline konseptual yang dapat digunakan oleh kajian-kajian lanjutan dalam program riset yang sama, khususnya yang hendak mendalami aspek regulasi, deteksi teknis, maupun respons kebijakan terhadap RaaS.

1.2 Rumusan Masalah

- a) RQ1 – Bagaimana model RaaS berbeda dari ransomware konvensional dalam hal pembagian peran dan *revenue* antara pengembang dan afiliasi?
- b) RQ2 – Apa saja komponen ekosistem RaaS (*developer*, afiliasi, *Initial Access Broker*) dan bagaimana pola interaksi di antara mereka?
- c) RQ3 – Bagaimana mekanisme *vetting* afiliasi dalam RaaS mencerminkan selektivitas yang melampaui sekadar motif finansial?

1.3 Tujuan Penelitian

- a) Mengidentifikasi dan membandingkan struktur pembagian peran serta skema *revenue sharing* pada RaaS versus ransomware konvensional.
- b) Memetakan komponen ekosistem RaaS beserta pola interaksi antar-aktornya ke dalam sebuah tipologi hubungan.
- c) Menginterpretasikan mekanisme *vetting* afiliasi sebagai instrumen tata kelola informal, bukan semata penyaring finansial.

1.4 Manfaat Penelitian

Manfaat teoritis pada penelitian ini adalah memberikan definisi operasional dan tipologi aktor RaaS yang dapat menjadi rujukan konseptual bagi penelitian lanjutan di bidang kriminologi siber, ekonomi kejahatan digital, dan studi tata kelola non-negara. Adapun manfaat praktisnya adalah peta konseptual dan matriks *state-of-the-art* (SOTA) yang dihasilkan dapat membantu praktisi keamanan siber, pembuat kebijakan, dan lembaga penegak hukum dalam memahami titik-titik intervensi potensial pada rantai nilai RaaS, termasuk pada tahap rekrutmen dan *vetting* afiliasi.

1.5 Batasan Masalah

- a) Penelitian tidak melakukan pengumpulan data primer dari forum *dark web* atau observasi langsung transaksi kriminal; seluruh data bersumber dari literatur dan laporan yang telah dipublikasikan secara terbuka.
- b) Korpus literatur dibatasi pada 12 dokumen kurasi program riset (10 karya akademik/preprint dan 2 laporan insiden/*threat-intelligence* kontemporer), bukan tinjauan sistematis (*systematic review*) yang menyeluruh atas seluruh literatur RaaS yang ada.
- c) Analisis difokuskan pada tiga keluarga/kasus RaaS yang paling banyak didokumentasikan dalam korpus (Conti, LockBit, dan kasus-kasus pembandingan seperti DarkSide, BlackCat/ALPHV, Hive, serta VECT sebagai kasus kontras) sebagai unit ilustrasi, bukan generalisasi menyeluruh atas seluruh varian RaaS yang pernah tercatat.
- d) Diskusi keterkaitan aktor negara bersifat interpretatif berdasarkan pola yang dilaporkan sumber sekunder, bukan klaim atribusi forensik yang divalidasi secara independen oleh penelitian ini.

1.6 Sistematika Penulisan

Naskah ini disusun mengikuti sistematika sebagai berikut. Bagian 1 (Pendahuluan) menguraikan latar belakang, rumusan masalah, tujuan, manfaat, dan batasan penelitian. Bagian 2 (Metodologi) menjelaskan desain penelitian deskriptif-eksplanatif, sumber data, prosedur triase, dan teknik analisis yang digunakan. Bagian 3 (Hasil dan Pembahasan) menyajikan temuan atas RQ1–RQ3 beserta matriks *state-of-the-art* dan peta konseptual ekosistem RaaS. Bagian 4 (Kesimpulan) merangkum jawaban atas ketiga RQ, kontribusi, keterbatasan, dan arah penelitian lanjutan, yang selanjutnya menjadi fondasi bagi pengembangan proposal penelitian yang lebih lengkap (Bab 1–3) pada tahap Ujian Akhir Semester.

2. Metodologi

2.1 Desain Penelitian

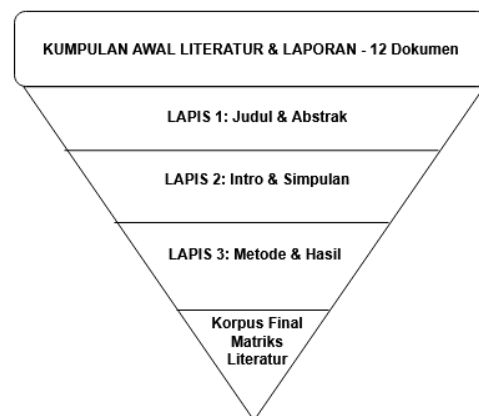
Penelitian ini menggunakan pendekatan deskriptif-eksplanatif (*descriptive-explanatory research*) melalui studi pustaka dan analisis dokumen sekunder. Pendekatan ini dipilih karena fenomena yang diteliti—struktur organisasi, pembagian peran, dan mekanisme tata kelola ekosistem RaaS—bersifat struktural-kualitatif dan sulit direduksi menjadi variabel terukur tunggal beserta hipotesis kausal. Penelitian ini secara sadar tidak merumuskan variabel independen-dependen, tidak menguji hipotesis statistik, dan tidak melakukan pengukuran kuantitatif atas populasi sampel; tujuannya adalah menjelaskan dan menginterpretasikan pola yang telah didokumentasikan oleh sumber-sumber sekunder ke dalam kerangka konseptual yang koheren.

2.2 Sumber dan Kriteria Data

Data bersumber dari korpus kurasi 12 dokumen yang terdiri atas: (a) lima karya akademik/preprint inti yang membahas ekonomi dan organisasi RaaS secara langsung [1], [3], [4], [5], [6]; (b) dua laporan yang membahas dimensi kebijakan dan geopolitik [9], [10]; (c) dua laporan/kajian teknis-forensik [2], [7]; (d) satu kajian tentang infrastruktur akses awal [8]; dan (e) dua laporan insiden kontemporer sebagai studi kasus kontras [11], [12]. Kriteria inklusi: dokumen membahas minimal satu dari tiga pertanyaan penelitian dan telah dipublikasikan secara terbuka (jurnal, *preprint server*, laporan lembaga riset, atau media investigatif tepercaya). Kriteria eksklusi: sumber yang mensyaratkan akses langsung ke forum kriminal tertutup atau *dark web*, sebagaimana dinyatakan pada batasan masalah.

2.3 Prosedur Triase Tiga Lapis

Seleksi relevansi setiap dokumen terhadap RQ1–RQ3 dilakukan melalui prosedur triase tiga lapis: Lapis 1 menyaring berdasarkan judul dan abstrak untuk menilai kesesuaian tematik umum; Lapis 2 menelaah bagian pendahuluan dan kesimpulan untuk memastikan kontribusi substantif terhadap salah satu RQ; Lapis 3 melakukan inspeksi mendalam atas metodologi dan temuan guna mengekstraksi data yang dapat dibandingkan lintas sumber (Gambar 1). Seluruh dokumen dalam korpus kurasi berhasil melewati triase ini dan dimasukkan ke dalam matriks literatur final.



Prosedur Triase Tiga Lapis

Gambar 1. Prosedur Triase Tiga Lapis Seleksi Literatur

2.4 Teknik Analisis Data

Analisis dilakukan melalui *matriks state-of-the-art* (SOTA) yang membandingkan setiap sumber berdasarkan kolom Penulis, Metode, Dataset/Sumber Data, Fokus/Metrik, Hasil Utama, Kelebihan, dan Kekurangan (lihat Tabel 1 pada Bagian 3). Data dari matriks tersebut kemudian dianalisis secara tematik dengan kombinasi pendekatan deduktif (mengelompokkan temuan ke dalam tiga tema besar sesuai RQ1–RQ3) dan induktif (membiarkan pola baru, seperti diskrepansi angka bagi hasil antar sumber, muncul dari data itu sendiri). Perbandingan lintas sumber (*cross-source comparison*) digunakan untuk menyintesis peta konseptual ekosistem (Gambar 2) sebagai representasi visual dari tipologi hubungan antar aktor yang teridentifikasi.

2.5 Keterbatasan Metodologis

- Ekstraksi dan interpretasi tema dilakukan oleh satu peneliti (*single coder*) tanpa proses *inter-rater reliability*, sehingga berpotensi mengandung bias interpretatif.
- Beberapa sumber utama—[1], [6], [10]—berstatus *preprint* atau laporan lembaga riset yang belum/tidak melalui proses peer-review jurnal formal pada saat diakses, sehingga temuannya diperlakukan sebagai indikatif, bukan definitif.
- Data yang digunakan bergantung pada rekonstruksi sumber sekunder atas materi yang sebagian berasal dari kebocoran data kriminal (misalnya kebocoran internal Conti); akurasi angka tidak dapat diverifikasi ulang secara independen oleh penelitian ini.
- Perbedaan angka rasio bagi hasil antar sumber (misalnya 85:15 pada [1] versus 20–30% pada [7]) diperlakukan sebagai temuan yang perlu didiskusikan, bukan *noise* yang harus diseragamkan secara paksa.

3. Hasil Dan Pembahasan

3.1 Perbedaan Model RaaS dan Ransomware Konvensional

Ransomware konvensional secara historis dimodelkan sebagai transaksi dua pihak antara satu penyerang dan satu korban, sebagaimana direpresentasikan oleh model permainan klasik yang menyatakan korban rasional akan membayar tebusan r hanya jika $r \leq L/b$ (dengan L sebagai kerugian akibat kehilangan data dan b sebagai faktor keyakinan pemulihan) [3]. Model tunggal ini secara eksplisit tidak lagi memadai untuk menjelaskan RaaS, karena RaaS memisahkan peran *developer* (pembuat platform) dari afiliasi (pelaksana serangan lapangan) melalui skema bagi hasil yang eksplisit dan berulang.

Bukti empiris atas analisis dompet *blockchain* afiliasi menunjukkan bahwa rasio bagi hasil rata-rata pada RaaS adalah 85:15 (afiliasi: *developer*), dengan variasi antar keluarga: NetWalker 85:15, REvil 90:10, DarkSide sekitar 93:7, dan Conti 75:25 [1]. Rata-rata nilai tebusan pada model RaaS (juga tercatat enam kali lebih tinggi (\$14.580) dibandingkan ransomware komoditas non-RaaS (\$2.470)), dan RaaS menyumbang lebih dari 90% total pendapatan ransomware yang teridentifikasi meski hanya mewakili sebagian dari total insiden [1]. Yang tidak kalah penting, pendapatan model RaaS terbukti tumbuh secara eksponensial seiring bertambahnya usia operasi dan reputasi—sekitar \$43.680 tambahan pendapatan per bulan usia operasi—sementara ransomware konvensional justru stagnan atau menurun setelah tahun pertama beroperasi [1]. Pola ini konsisten dengan temuan bahwa nilai tuntutan tebusan rata-rata meningkat drastis dari sekitar \$5.000 pada 2017 menjadi \$500.000 pada 2023, seiring menurunnya hambatan masuk (*entry barrier*) bagi calon afiliasi berkat tersedianya kit siap pakai [4].

Struktur organisasi internal RaaS turut mengonfirmasi pergeseran dari kejahatan individual menjadi entitas menyerupai perusahaan. Analisis atas kebocoran data internal Conti mengungkap total pendapatan operasi sekitar \$104,4 juta berbanding total pengeluaran \$31,2 juta, termasuk \$21,9 juta untuk gaji staf yang mencakup tim manajemen, tim pengembang/infrastruktur (52 orang, \$97.447/bulan), tim *reverse engineering* (16 orang, \$23.347/bulan), tim riset (6 orang, \$12.500/bulan), dan tim OSINT (4 orang, \$9.000/bulan) [6]. Dari 32 alamat dompet tebusan yang berhasil dikonfirmasi, 53% menunjukkan pola pembagian dua-dompet dengan proporsi bagi hasil 5–40% (paling umum 20%), sementara pada operasi Ryuk (pendahulu Conti) proporsi paling umum adalah 35% [6]. Tabel 1 merangkum perbandingan sepuluh sumber literatur yang menjadi basis analisis ini.

Penting dicatat bahwa terdapat diskrepansi angka antar sumber: analisis forensik atas LockBit melaporkan estimasi bagi hasil operator hanya 20–30% dari nilai tebusan [7]—berkebalikan dengan pola 85:15 (favor afiliasi) yang dilaporkan sumber lain [1]. Diskrepansi ini kemungkinan besar berasal dari perbedaan definisi "*split*" yang diukur (porsi dari total nilai tebusan versus porsi dari *margin* setelah biaya operasional) serta perbedaan metodologi ekstraksi data (observasi *on-chain* langsung versus estimasi analisis pihak ketiga). Alih-alih diselaraskan secara paksa, diskrepansi ini justru memperkuat argumen utama penelitian ini: rasio bagi hasil RaaS bukan angka tunggal yang tetap, melainkan hasil negosiasi yang bergantung pada reputasi, daya tawar afiliasi, dan kualitas dukungan yang ditawarkan *developer*—sebuah ciri yang sama sekali tidak dimiliki ransomware konvensional yang bersifat satu-kali-pakai.

Tabel 1. Matriks State-of-the-Art (SOTA) Literatur RaaS

Penulis (Tahun)	Metode	Dataset/Sumber	Fokus	Hasil Utama	Kelebihan	Kekurangan
Laszka dkk. (2017) [3]	Model permainan (game theory)	Model analitis, tanpa data empiris	Ekonomi keputusan bayar-tebusan	Kondisi rasional pembayaran $r \leq L/b$; celah Nash vs. optimum sosial	Fondasi teori formal yang kuat	Asumsi satu penyerang; tidak mencakup struktur multi-aktor RaaS
Gray dkk. (2023) [6]	Analisis dokumen bocoran + on-chain	Kebocoran internal Conti + blockchain	Struktur organisasi & keuangan	Revenue \$104,4jt; struktur gaji tim; pola split 2-dompet	Bukti langka struktur internal nyata	Studi kasus tunggal (Conti); belum peer-review formal
Fachkha dkk. (2025) [5]	Studi historis/kualitatif	Silsilah Babuk-GandCrab-Sodinokibi	Evolusi teknis & taktik bertahan	Modularitas & rebranding sbg strategi survival	Perspektif evolusi historis lintas keluarga	Tata kelola & geopolitik eksplisit di luar cakupan
Dhawan dkk. (2025) [1]	Analisis on-chain kuantitatif	Data transaksi blockchain 2010–2022	Ekonomi revenue-split & pertumbuhan	Split rata-rata 85:15; RaaS >90% revenue; tumbuh eksponensial	Data kuantitatif on-chain berskala besar	Preprint, belum peer-review formal
Masakapalli & Vodapally (2025) [4]	Tinjauan deskriptif + studi kasus	Studi kasus Colonial Pipeline & varian RaaS	Taktik & proposisi nilai varian RaaS	Pemetaan diferensiasi LockBit/BlackCat/Hive/DarkSide	Perbandingan varian yang kaya	Minim data kuantitatif primer
Bhattarai (2025) [7]	Analisis forensik teknis	Sampel LockBit + laporan kasus Boeing/Royal Mail	Perilaku teknis & dampak insiden	Estimasi split operator 20–30%; perilaku anti-VM/sandbox	Detail forensik hands-on	Estimasi split tidak terverifikasi silang
Qollakaj & Larsson (2023) [8]	Tinjauan kerentanan VPN	CVE publik & laporan CrowdStrike	Infrastruktur akses awal (IAB)	IAB meningkat 112%; kerentanan VPN sama dipakai APT & kriminal	Menjembatani akses awal kriminal & negara	Fokus teknis VPN, minim analisis aktor RaaS lain
Ferdous dkk. (2024) [2]	Tinjauan literatur deteksi AI	Korpus paper deteksi ransomware berbasis AI	Tren serangan & efektivitas deteksi	Serangan naik 73%; LockBit 23% serangan Q1 2024	Kontekstualisasi urgensi dari sisi pertahanan	Tidak membahas ekosistem/organisasi RaaS langsung
Iwasaki & Masaki (2025) [9]	Analisis kebijakan/hukum	Studi regulasi larangan pembayaran	Dampak kebijakan larangan bayar	Larangan total berisiko mendorong ekonomi bayangan	Menghubungkan RaaS dgn respons kebijakan negara	Preprint/jurnal baru, belum banyak disitasi
Milenkoski dkk. (2025) [10]	Analisis kualitatif geopolitik	Laporan kasus lintas Rusia/Korea Utara/Tiongkok/Iran	Keterkaitan RaaS & aktor negara	5 mekanisme kooptasi negara teridentifikasi	Cakupan geopolitik lintas negara luas	Bergantung atribusi pihak ketiga, sulit diverifikasi independen

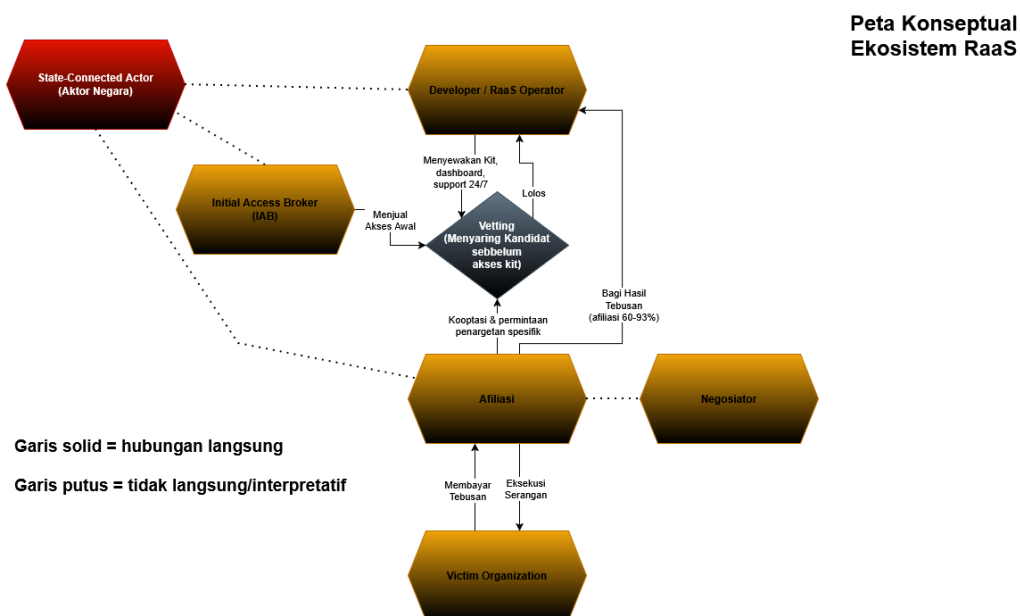
3.2 Komponen Ekosistem dan Interaksi Antar Aktor

Ekosistem RaaS terbentuk dari beberapa aktor dengan peran dan insentif yang berbeda, namun saling bergantung dalam satu rantai nilai. Developer/operator RaaS membangun dan memelihara platform inti—termasuk mesin enkripsi, *dashboard* manajemen, portal kebocoran data, dan dukungan teknis 24/7—sekaligus menetapkan aturan main bagi afiliasi. Diferensiasi proposisi nilai antar operator RaaS cukup jelas: LockBit dikenal dengan kecepatan enkripsi di bawah lima menit menggunakan kombinasi AES-128 dan RSA-2048; BlackCat/ALPHV menonjolkan implementasi berbasis Rust yang lintas platform dengan skema *double extortion* memakai ChaCha20-Poly1305; Hive menawarkan portal kebocoran data khusus yang modular; sementara DarkSide dikenal karena pendekatan penargetan yang selektif disertai tim hubungan masyarakat internal untuk mengelola narasi publik pascaserangan [4].

Afiliasi adalah pihak yang menyewa akses ke kit RaaS dan mengeksekusi serangan di lapangan, termasuk melakukan negosiasi langsung dengan korban. Analisis atas 215 transkrip negosiasi menunjukkan bahwa 197 di antaranya (91,6%) menampilkan pola komunikasi tim, bukan individu, dengan 71% interaksi terjadi melalui kanal semacam *customer support*; rata-rata afiliasi berhasil menegosiasikan diskon sebesar 43% dari tuntutan awal dalam rentang waktu rata-rata 18 hari, dan hanya sekitar 6% korban yang menolak membayar sama sekali [1]. Pola ini menegaskan bahwa afiliasi RaaS beroperasi lebih menyerupai tenaga penjualan profesional ketimbang penjahat oportunistik lepas.

Initial Access Broker (IAB) adalah aktor yang mengkhususkan diri menjual akses awal ke jaringan korban (misalnya kredensial VPN atau RDP) tanpa perlu terlibat dalam eksekusi ransomware itu sendiri. Populasi penjual IAB tercatat meningkat 112% pada 2022, dan sebagian besar akses yang diperdagangkan diperoleh melalui eksploitasi kerentanan VPN populer—termasuk Fortinet (CVE-2018-13379, peningkatan eksploitasi 1.919%) dan Pulse Secure (CVE-2019-11510, peningkatan 1.527%) [8]. Temuan ini menegaskan bahwa IAB bukan sekadar sub-kategori afiliasi, melainkan aktor ekonomi mandiri yang dapat menjual akses yang sama kepada operator RaaS mana pun yang membayar paling tinggi, sebagaimana diilustrasikan oleh kasus Colonial Pipeline: akses awal diperoleh lewat satu akun VPN tanpa autentikasi multifaktor, dieksploitasi untuk mengeksfiltrasi sekitar 100GB data, berujung pada tuntutan tebusan \$4,4 juta dan penghentian operasional jalur pipa sepanjang 5.500 mil [4].

Korban menempati posisi akhir rantai nilai, sementara negosiator dapat berupa peran khusus dalam tim afiliasi (sebagaimana pola tim pada Conti) atau melekat pada individu yang sama dengan operator serangan pada operasi berskala lebih kecil. Interaksi antar seluruh aktor ini, termasuk titik masuk mekanisme vetting yang menjadi gerbang sebelum afiliasi memperoleh akses ke kit, serta potensi keterlibatan aktor negara yang akan dibahas pada Bagian 3.4, dirangkum secara visual pada Gambar 2.



Gambar 2. Peta Knsseptual Ekosistem Ransomware as a Service

3.3 Mekanisme Vetting Afiliasi sebagai selektifitas Melampaui Motif Finansial

Temuan paling substantif dari penelitian ini terletak pada mekanisme *vetting* (penyaringan) afiliasi. Analisis atas Conti menunjukkan bahwa rekrutmen afiliasi menempuh dua jalur paralel: jalur bawah tanah melalui forum kriminal seperti XSS dan Exploit, serta jalur yang tampak sah melalui platform lowongan kerja umum seperti LinkedIn, HeadHunter, Avito, dan Profi.ru—dengan lowongan yang disamarkan

sebagai pekerjaan IT biasa [6]. Pada jalur bawah tanah, calon afiliasi disaring melalui kombinasi reputasi/vouching dari anggota lama, riwayat transaksi di forum, dan uji kompetensi teknis (semacam tes pemrograman) sebelum diberi akses ke kit dan infrastruktur [6]. Pola ini menunjukkan bahwa *vetting* RaaS tidak sekadar menyaring siapa yang mampu membayar fee lisensi, melainkan menyaring siapa yang kompeten secara teknis dan dapat dipercaya untuk tidak mengkhianati operasi atau membocorkan informasi ke penegak hukum—sebuah fungsi yang secara struktural setara dengan proses rekrutmen dan *due diligence* pada organisasi bisnis yang sah.

Argumen ini diperkuat oleh kontras dengan kasus operasi yang meniadakan *vetting* ketat. Laporan atas ransomware VECT 2.0 mendokumentasikan model afiliasi terbuka di mana siapa pun dapat mendaftar melalui forum publik BreachForums tanpa proses penyaringan reputasi maupun kompetensi yang berarti. Konsekuensinya, kit tersebut justru mengandung cacat teknis serius yang membuatnya berfungsi sebagai *data wiper* (penghancur data permanen) alih-alih ransomware fungsional yang dapat memulihkan data setelah pembayaran [11]. Kontras ini menegaskan logika kausal di balik *vetting*: ketika seleksi afiliasi diabaikan demi memperluas jangkauan secara cepat, kualitas eksekusi teknis dan keandalan operasi ikut merosot—yang pada akhirnya merugikan reputasi dan model bisnis operasi itu sendiri. Dengan kata lain, *vetting* berfungsi sebagai instrumen kendali mutu (*quality control*) sekaligus tata kelola informal, bukan semata gerbang pembayaran.

Namun, sifat tata kelola informal ini tetap rapuh secara etis dan pada akhirnya tunduk pada kalkulasi finansial. Analisis atas Conti mengungkap bahwa kelompok ini tetap menyerang *Health Service Executive* (HSE) Irlandia—sebuah penyedia layanan kesehatan publik—meski terdapat norma informal di kalangan sebagian pelaku ransomware yang menghindari penargetan fasilitas kesehatan [6]. Hal ini menunjukkan bahwa norma-norma informal yang menyertai *vetting* dan rekrutmen (misalnya batasan target tertentu) bersifat preferensi kolektif yang dapat dilanggar, bukan aturan tegas yang mengikat secara mutlak, sehingga *vetting* afiliasi RaaS lebih tepat dipahami sebagai tata kelola kuasi-korporat yang pragmatis—menyeimbangkan kebutuhan akan kompetensi, kepercayaan, dan profitabilitas—ketimbang sistem etika yang konsisten. Mekanisme penegakan pembayaran dalam ekosistem ini juga bersandar pada transparansi *blockchain* itu sendiri, di mana afiliasi dapat memverifikasi secara publik apakah pembagian hasil telah dilaksanakan sesuai kesepakatan [1], berfungsi sebagai bentuk penegakan kuasi-kontraktual tanpa keberadaan hukum formal yang mengikat.

3.4 Sintesis Tata Kelola dan Implikasi Ketertarikan Aktor Negara

Ketiga temuan di atas—pemisahan peran dengan bagi hasil yang dinegosiasikan, ekosistem multi-aktor dengan IAB sebagai entitas mandiri, dan *vetting* sebagai tata kelola kuasi-korporat berbasis kompetensi-kepercayaan—bersama-sama menunjukkan bahwa RaaS telah berevolusi menjadi struktur organisasi yang matang, terdesentralisasi, dan resisten terhadap intervensi hukum konvensional. Kesenjangan antara keseimbangan Nash (perilaku individual rasional) dan optimum sosial dalam model ekonomi ransomware klasik [3] semakin melebar ketika diterapkan pada struktur RaaS: setiap aktor (*developer*, afiliasi, IAB) mengoptimalkan kepentingannya sendiri melalui mekanisme pasar informal (reputasi, *bidding* akses, negosiasi bagi hasil), sehingga sulit diintervensi melalui satu titik kebijakan tunggal. Kondisi ini turut dipersulit oleh paradoks kebijakan larangan total pembayaran tebusan: larangan yang tidak disertai infrastruktur pelaporan dan *safe harbor* yang memadai berisiko mendorong transaksi ke ekonomi bayangan yang lebih sulit dipantau, alih-alih menghilangkannya [9].

Kematangan struktural inilah yang menjelaskan mengapa aktor negara tertarik memanfaatkan ekosistem RaaS. Sedikitnya lima mekanisme keterlibatan negara teridentifikasi dari "empat besar" negara (Rusia, Korea Utara, Tiongkok, dan Iran): (1) kooptasi langsung, misalnya dugaan keterlibatan aparat keamanan Rusia (FSB) dengan kelompok Conti; (2) koneksi relasional antara pelaku individual seperti jaringan Evil Corp dan pejabat negara; (3) moonlighting kontraktor, sebagaimana kasus perusahaan kontraktor siber i-Soon di Tiongkok yang diduga merangkap operasi komersial dan negara; (4) adopsi kapabilitas RaaS siap pakai oleh kelompok yang berafiliasi negara, misalnya dugaan penggunaan kit bergaya LockBit oleh kelompok Bronze Starlight serta penggunaan Ryuk/LockBit 2.0 oleh aktor yang diasosiasikan dengan Korea Utara; dan (5) partisipasi langsung dalam rantai nilai sebagai afiliasi atau IAB, seperti dugaan

keterlibatan kelompok Pioneer Kitten (Iran) dengan operasi NoEscape/BlackCat dan kelompok Andariel dengan ransomware Play [10]. Data *on-chain* pendukung memperkirakan sekitar 74% pendapatan ransomware pada 2021 mengalir ke kelompok berbasis Rusia, sementara pendanaan program rudal balistik Korea Utara diperkirakan sebagian berasal dari pencurian siber dan ekstorsi [10].

Yang secara khusus relevan dengan RQ2 dan RQ3 adalah temuan bahwa infrastruktur akses awal yang dieksploitasi aktor negara dan aktor kriminal murni kerap identik: kelompok yang diasosiasikan dengan Iran (Fox Kitten/APT34) dan Tiongkok (UNC2630) tercatat mengeksploitasi kerentanan VPN yang sama dengan yang dipakai IAB kriminal untuk menjual akses kepada afiliasi RaaS [8], sementara Pioneer Kitten dilaporkan secara sengaja menyamarkan asal-usul Irannya ketika berinteraksi dengan afiliasi ransomware demi menjaga *plausible deniability* [10]. Pola ini mengindikasikan bahwa mekanisme vetting afiliasi RaaS, sejauh yang terdokumentasikan, tidak dirancang untuk menyaring afiliasi berdasarkan asal-usul negara—artinya komoditisasi infrastruktur akses awal justru menjadi celah struktural yang membuat keterlibatan negara relatif mudah disamarkan di dalam ekosistem yang sama. Perlu ditegaskan bahwa bukti langsung mengenai keterkaitan negara dalam korpus penelitian ini masih tipis dan sebagian besar bersifat interpretatif dari laporan geopolitik [10] serta catatan tidak langsung pada kajian kerentanan infrastruktur [8]; oleh karena itu, sintesis pada bagian ini sebaiknya diperlakukan sebagai arah kajian lanjutan bagi program riset ini, bukan kesimpulan final yang telah tervalidasi secara empiris menyeluruh.

4. Kesimpulan

Penelitian ini menyimpulkan tiga hal utama. Pertama (RQ1), RaaS berbeda secara fundamental dari ransomware konvensional karena memisahkan peran *developer* dan afiliasi melalui skema bagi hasil yang dinegosiasikan (rata-rata 85:15) dan tumbuh eksponensial seiring reputasi, alih-alih model serangan tunggal yang stagnan. Kedua (RQ2), ekosistem RaaS terdiri atas *developer*, afiliasi, dan *Initial Access Broker* yang berinteraksi sebagai aktor ekonomi yang secara struktural independen satu sama lain, dihubungkan melalui pasar informal jual-beli akses dan kit, sebagaimana dirangkum dalam peta konseptual pada Gambar 2. Ketiga (RQ3), mekanisme *vetting* afiliasi berfungsi sebagai instrumen tata kelola kuasi-korporat yang menyaring kompetensi teknis dan kepercayaan, bukan semata kemampuan membayar—meskipun tata kelola informal ini tetap rapuh dan dapat dikalahkan oleh kalkulasi finansial semata.

Kontribusi utama penelitian ini adalah definisi operasional dan tipologi aktor RaaS (Gambar 2) beserta matriks *state-of-the-art* (Tabel 1) yang dapat menjadi baseline konseptual bagi kajian lanjutan dalam program riset yang sama—baik yang hendak mendalami deteksi teknis, respons kebijakan, maupun analisis forensik atas keluarga RaaS tertentu. Kematangan struktural dan sifat resisten-regulasi ekosistem ini turut menjelaskan mengapa aktor negara tertarik untuk berkooptasi, membangun relasi, menugaskan kontraktor rangkap, mengadopsi kapabilitas RaaS siap pakai, atau berpartisipasi langsung sebagai afiliasi/IAB.

Penelitian ini memiliki keterbatasan yang perlu diperhatikan pada kajian lanjutan: korpus yang digunakan terbatas pada 12 dokumen kurasi (bukan tinjauan sistematis menyeluruh), sebagian sumber utama berstatus *preprint* yang belum melalui *peer-review* formal, dan sintesis mengenai keterkaitan aktor negara masih bersifat interpretatif. Kajian lanjutan disarankan untuk: (a) memvalidasi secara empiris pola keterkaitan negara-RaaS melalui data atribusi forensik independen; (b) memperdalam studi mekanisme *vetting* afiliasi melalui data forum tambahan dengan kerangka etik penelitian yang ketat; dan (c) membandingkan respons kebijakan lintas yurisdiksi terhadap larangan atau regulasi pembayaran tebusan.

Ucapan Terima Kasih

Penulis mengucapkan terima kasih kepada Bapak Hendri Karisma, M.T. selaku dosen pengampu mata kuliah Metodologi Penelitian, Program Studi Teknik Informatika, STMIK Tazkia, atas bimbingan dalam penyusunan proposal penelitian ini.

Daftar Pustaka

- [1] A. Dhawan, S. Foley, and V. Mollica, "Splitting the Spoils: The Economics of Ransomware as a Service," *SSRN Electronic Journal* (preprint, belum melalui peer-review formal), 2025.
- [2] J. Ferdous, R. Islam, A. Mahboubi, and M. Z. Islam, "AI-Based Ransomware Detection: A Comprehensive Review," *IEEE Access*, vol. 12, pp. 136666–136695, 2024, doi: 10.1109/ACCESS.2024.3461965.
- [3] A. Laszka, S. Farhang, and J. Grossklags, "On the Economics of Ransomware," *arXiv preprint arXiv:1707.06247*, 2017.
- [4] N. Masakapalli and R. Vodapally, "Ransomware as a Service (RaaS): Emerging Threats and Proactive Defense Tactics," *IRE Journals*, vol. 8, no. 10, 2025.
- [5] C. Fachkha, S. Razaualla, C. Markarian, A. Gawanmeh, B. C. M. Fung, and C. Assi, "Ransomware-as-a-Service and Its Evolution: Lessons from the Babuk, GandCrab, and Sodinokibi Families," *Preprint/Institutional Report*, University of Dubai, McGill University, and Concordia University, 2025.
- [6] I. W. Gray, J. Cable, B. Brown, V. Cuiujuclu, and D. McCoy, "Money Over Morals: A Business Analysis of Conti Ransomware," *arXiv preprint arXiv:2304.11681*, 2023.
- [7] K. Bhattarai, "Dissecting LockBit Ransomware: From Infection to Impact," *Independent Research Report*, 2025, doi: 10.13140/RG.2.2.13204.87687.
- [8] K. Qollakaj and L. Einler Larsson, "Cybersecurity of Remote Work Migration: A Study on the VPN Security Landscape Post COVID-19 Outbreak," *Bachelor Thesis*, Blekinge Institute of Technology, 2023.
- [9] M. Iwasaki, "Banning Ransomware Payments: Unintended Effects on Cybersecurity Investment and Incident Reporting," *International Cybersecurity Law Review*, vol. 6, pp. 17–27, 2025, doi: 10.1365/s43439-025-00137-5.
- [10] A. Milenkoski, J. Minier, J.-F. Vögele, M. Smeets, and T. Grossman, "Ransomware's New Masters: How States Are Hijacking Cybercrime," *Virtual Routes, Pharos Series*, Report No. 3, 2025.
- [11] Check Point Research, "VECT: Ransomware by Design, Wiper by Accident," *Check Point Research Blog*, Apr. 2026.
- [12] S. Jain, "Latvian National Sentenced for Role in Multi-Million Dollar Ransomware Scheme," *The Cyber Express*, May 2026.